

Шпаргалка по Nmap

Инвентаризация сети и проверка доступности служб: выбор целей, обнаружение узлов, виды сканирования портов, определение служб и системы, скрипты, форматы вывода и разбор результатов.

Прежде всего

Сканируйте только те узлы, которыми владеете или на проверку которых получили письменное разрешение. Сканирование чужих сетей во многих странах противозаконно, а агрессивные режимы вдобавок мешают работе служб.

Как задать цели

```
nmap 192.168.1.10
    Один адрес или имя узла
nmap 192.168.1.0/24
    Подсеть
nmap 192.168.1.1-50
    Диапазон
nmap -iL hosts.txt
    Список целей из файла
--exclude 192.168.1.1,192.168.1.5
    Исключить адреса
```

Обнаружение узлов

```
nmap -sn 192.168.1.0/24
    Только поиск живых узлов, без сканирования портов
nmap -Pn цель
    Считать узел активным и не проверять доступность:
    помогает, когда ICMP закрыт
nmap -PS22,80,443 цель
    Проверка доступности пакетами TCP SYN на указанные
    порты
nmap -n цель
    Не разрешать имена — заметно быстрее
nmap -R цель
    Наоборот, разрешать имена всегда
```

Виды сканирования портов

```
-sS
    Полуоткрытое SYN-сканирование: быстрое, требует
    прав root. Режим по умолчанию при наличии прав
-sT
    Полное TCP-подключение: работает без особых прав
-sU
    UDP: медленно, но там живут DNS, SNMP, NTP
-sA
    ACK-сканирование: показывает, фильтруется ли порт
-p 22,80,443 / -p 1-1000 / -p-
    Конкретные порты, диапазон, все 65 535
--top-ports 100
    Сотня самых распространённых портов
-F
    Быстрый режим: сокращённый список портов
```

Что за службой

```
-sV
    Определение службы и её версии
--version-intensity 0-9
    Глубина проверки версии
-O
    Предположение об операционной системе
-A
    Всё сразу: версии, система, скрипты, трассировка.
    Шумно и небыстро
--traceroute
    Путь до узла
```

Скрипты NSE

```
-sC
    Набор стандартных безопасных скриптов
--script=http-title,ssl-cert
    Конкретные скрипты
--script=default,safe
    Категории: default, safe, discovery, version
--script-help=ssl-*
    Описание скриптов по маске
--script=ssl-enum-ciphers -p 443
    Наборы шифров TLS на узле
--script-args=...
    Параметры скрипта
Категории intrusive, exploit и brute нагружают и могут
нарушить работу службы — на рабочих системах без
согласования не применяйте.
```

Скорость и точность

```
-T0 ... -T5
    Шаблоны времени: 0 — предельно медленно, 3 —
    обычный, 4 — быстрый и приемлемый для своей сети, 5
    — агрессивный
--min-rate 1000 / --max-rate
    Число пакетов в секунду
--host-timeout 30m
    Не тратить на узел больше указанного времени
--max-retries 2
    Меньше повторов — быстрее, но выше риск пропустить
    порт
-v / -vv / -d
    Подробность вывода и отладка
--reason
    Почему порт признан открытым или закрытым
```

Вывод

```
-oN scan.txt
    Обычный текстовый отчёт
-oX scan.xml
    XML для обработки и отчётов
-oG scan.gnmap
    Формат, удобный для grep
-oA scan
    Все три формата разом

--append-output
    Дописывать в существующий файл

--resume scan.txt
    Продолжить прерванное сканирование
```

Состояния портов

- **open** — служба принимает подключения.
- **closed** — узел доступен, но порт не занят.
- **filtered** — ответа нет: мешает межсетевой экран или правило фильтрации.
- **unfiltered** — порт доступен, но открыт он или нет, определить не удалось.
- **open|filtered** — типично для UDP: ответа нет, и это может значить и то и другое.

Типовые запуски

```
# Быстрая инвентаризация своей подсети
nmap -sn 10.0.0.0/24

# Порты и версии служб на сервере
sudo nmap -sS -sV -p- -T4 10.0.0.5 -oA server-scan

# Проверка веб-узла и его сертификата
nmap -p 80,443 --script=http-title,ssl-cert,ssl-enum-ciphers example.com

# Основные службы UDP
sudo nmap -sU --top-ports 20 10.0.0.5

# Что изменилось с прошлого раза
ndiff prev.xml curr.xml
```

Замечания

- Многие режимы требуют прав root: без них Nmap молча переключается на -sT.
- Сканирование через NAT и VPN даёт искажённую картину — проверяйте изнутри нужной сети.
- Системы обнаружения вторжений реагируют на сканирование: предупреждайте своих администраторов заранее.
- Полное сканирование -p- по большой подсети занимает часы — сужайте цели и порты.
- Графический интерфейс Zenmap удобен для разбора результатов, но в сценариях лучше XML и ndiff.